PLAYBOOK DE RESPUESTA

PB-02 | Malware detectado por EDR

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Gestionar detecciones Kaspersky en Windows/macOS y distinguir pruebas EICAR de ejecución de malware real.

02. Disparador, fuente y umbral

Kaspersky: evento de amenaza y bloqueo. Wazuh puede recibir eventos Windows del canal Kaspersky Endpoint Security; la regla personalizada 100510 fue propuesta, no se confirmó su disparo.

03. Severidad inicial y promoción

Media si una muestra fue bloqueada en un equipo (incluida la prueba EICAR); Alta si se ejecuta, se repite o afecta activo crítico; Crítica ante ransomware activo o propagación.

04. Triage: validación paso a paso

1. Verificar resultado exacto: bloqueado, detectado, desinfectado, cuarentena o ejecución.
2. Registrar host, usuario, proceso, ruta, hash y canal de entrada (web/correo/USB).
3. Validar si el identificador EICAR-Test-File pertenece a prueba acordada.
4. Buscar mismo hash o nombre en otros agentes y activos de pago.
5. Revisar en Wazuh presencia del evento y separar ingestión de correlación personalizada.

05. Contención autorizada a N1

- Poner en cuarentena según política activa; conservar evidencia.
- Aislar endpoint si hay ejecución/propagación con severidad alta/crítica e informar a N2.

06. Acciones no autorizadas a N1

- No borrar evidencia, desactivar el EDR ni apagar el sistema sin instrucción.
- No informar infección real basándose únicamente en EICAR.

07. Evidencia mínima preservada

- Captura de Kaspersky «descarga denegada», módulo Protección frente a amenazas web.
- Evento Windows del proveedor avp, ID 302, 21/10/2026 11:34:05 (laboratorio observado).
- Registro Wazuh archivado de la fuente, con decoder/campo y regla efectivamente observada.

08. Escalamiento obligatorio a N2

Ejecución real, propagación, servidor afectado, imposibilidad de remediar o indicador de fraude/robo de credenciales.

09. Criterios de cierre técnico

Con amenaza bloqueada y sin ejecución, realizar análisis de comprobación y documentar limitaciones de correlación.

10. Mejora continua

Validar regla específica por eventchannel, sin duplicados ni modificación informal de políticas.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-02 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.